

SMB Enumeration Lab - SecureCorp Internal Network

Tổng Quan

Bài lab này mô phỏng một **Internal Network Penetration Test** với kiến trúc **client-server** trong Docker network. Bạn sẽ đóng vai một pentester được thuê để kiểm tra bảo mật internal network của SecureCorp.

Kiến trúc: - **Server Container** (`smb_target`): Target với web, SMB, SSH services - **Client Container** (`smb_client`): Pentester machine với penetration testing tools - **Internal Network:** Containers giao tiếp qua Docker network

Kịch bản: Bạn được cấp quyền truy cập vào internal network của SecureCorp. Nhiệm vụ của bạn là: - Enumerate các dịch vụ đang chạy - Khai thác SMB shares để tìm thông tin - Tìm credentials và gain access vào hệ thống

Mục tiêu học tập: - Hiểu về SMB enumeration và password spraying - Khai thác lỗ hổng SMB shares với weak passwords - Tìm credentials trong network shares - Thực hiện lateral movement từ SMB sang SSH - Làm việc trong môi trường internal network

Cài Đặt Nhanh

Yêu Cầu

- Docker
- Docker Compose

Khởi Động Lab

```
cd smb-enum-lab
./start-lab.sh
```

Truy Cập Lab

Bước 1: Khởi động lab

```
cd /home/ubuntu/Desktop/bangiaolab/smb-enum-lab
./start-lab.sh
```

Bước 2: Exec vào client container

```
docker exec -it smb_client bash
```

Bước 3: Bắt đầu enumeration

```
# Scan services
nmap -p 445 smb-target

# Enumerate SMB shares
```

```
smbclient -L //smb-target -N
enum4linux -a smb-target
```

Thử Thách

Bạn được cấp quyền truy cập vào internal network của SecureCorp. Mục tiêu của bạn là:

1. **Khám phá** các dịch vụ đang chạy
2. **Enumerate** SMB shares và users
3. **Tìm hints** trong public share
4. **Password spraying** để truy cập protected shares
5. **Tìm credentials** trong network shares
6. **SSH login** và lấy flag

Flag format: FLAG{...}

Vị trí flag: Nằm trong thư mục home của user `sysadmin`.

Gợi Ý

Gợi ý 1: Scan services

Sử dụng nmap để scan các ports trên smb-target. Dịch vụ nào đang chạy?

Gợi ý 2: Enumerate SMB shares

Sử dụng smbclient hoặc enum4linux để liệt kê các shares. Share nào cho phép anonymous access?

Gợi ý 3: Tìm hints

Sau khi truy cập public share, hãy xem các files bên trong. Có file nào chứa hints không?

Gợi ý 4: Enumerate users

Sử dụng enum4linux để enumerate users. Username nào có thể dùng để password spraying?

Gợi ý 5: Password spraying

Sau khi tìm thấy username, thử các common passwords. Password thường là username + năm hoặc số.

Gợi ý 6: Tìm credentials

Sau khi truy cập được config share, hãy xem các files bên trong. Có file nào chứa credentials không?

Công Cụ Hữu Ích

- `nmap` - Port scanning
- `smbclient` - SMB client
- `enum4linux` - SMB enumeration tool
- `ssh` - SSH client
- `curl` hoặc trình duyệt web

SMB Shares

1. **documents** - Public access (read-only)
 - Contains: `readme.txt` với SMB credentials:
 - SMB Username: `sysadmin`
 - SMB Password: `Sy54dm1n`
2. **config** - Requires authentication
 - Accessible with SMB: `sysadmin / Sy54dm1n`
 - Contains: `config.txt` với SSH credentials:
 - SSH Username: `system`
 - SSH Password: `657sdfh85d`
3. **backup** - Requires authentication (optional)
 - Not used in main flow
 - Accessible with SMB: `sysadmin / Sy54dm1n`

Dọn Dẹp

Để dừng và xóa lab:

```
./stop-lab.sh
```

Để xóa hoàn toàn (bao gồm volumes):

```
docker-compose down -v
```

Tài Liệu Tham Khảo

- Hướng dẫn giải chi tiết - **CẢNH BÁO: SPOILER!**
- Thông tin lab

Lưu Ý Bảo Mật

Lab này được thiết kế cho mục đích **học tập** và **ngghiên cứu bảo mật**.

KHÔNG BAO GIỜ: - Sử dụng cấu hình này trong môi trường production
- Mở các port này ra internet công cộng - Sử dụng weak passwords trong hệ thống thực tế

Thông Tin Kỹ Thuật

Các lỗ hổng được mô phỏng: - SMB share với anonymous access - Weak passwords trên SMB shares - Credentials exposure trong network shares - SSH password authentication enabled - Không có account lockout - Username enumeration

Kỹ thuật tấn công: - Service enumeration - SMB enumeration - User enumeration - Password spraying - Credentials harvesting - Lateral movement (SMB → SSH)

Đóng Góp

Nếu bạn tìm thấy bug hoặc có ý tưởng cải thiện, vui lòng tạo issue hoặc pull request.

License

Lab này được tạo cho mục đích giáo dục. Sử dụng có trách nhiệm.

Happy Hacking!